

IRON4SOFTWARE

Sécurité des Systèmes d'Information

PLAN DE COMMUNICATION DE CRISE

Incident INC-2026-001

Ransomware avec exfiltration de données de santé

Champ	Valeur
Référence incident	INC-2026-001
Date de détection (T0)	19/04/2026 - 14h20 CEST
Classification	CRITIQUE - Violation de données de santé (Art. 9 RGPD)
Rédacteur	Responsable SOC / RSSI Iron4Software
Statut	CONFIDENTIEL - Diffusion restreinte direction et parties concernées
Version	1.0 - Document initial post-incident

*Document établi dans le cadre de la réponse à l'incident INC-2026-001.
Usage strictement confidentiel. Ne pas diffuser sans autorisation de la direction.*

1. Contexte de l'incident et cadre réglementaire

1.1 Synthèse de l'incident

Le **19 avril 2026 à 14h20 CEST**, le système SIEM de la société Iron4Software a déclenché 133 alertes critiques simultanées, révélant une intrusion majeure dans l'infrastructure de production. L'investigation forensique a permis de reconstituer une chaîne d'attaque démarrée le **7 mars 2026 à 09h19**, soit **43 jours avant la détection**.

L'attaquant a exploité une vulnérabilité d'upload de fichier sur le serveur web Apache (192.168.3.11) pour déposer un webshell, puis a pivoté vers le serveur Windows via un brute-force SMB ayant abouti à la compromission du compte Administrateur. Il a ensuite établi une session RDP interactive, exfiltré les données sensibles, et déployé un ransomware.

VIOLATION DE DONNÉES PERSONNELLES CONFIRMÉE

Le fichier **Dump_SQL_IronSuite_Clinique_StJean_PROD.bak** a été exfiltré depuis le serveur Windows. Ce fichier contient des données de santé de patients de la Clinique Saint-Jean, client d'Iron4Software.

Qualification RGPD : violation de données de catégorie particulière au sens de l'Article 9 du RGPD. Notification CNIL obligatoire sous 72h (Art. 33). Évaluation du risque pour les personnes concernées requise (Art. 34).

1.2 Chronologie synthétique de l'incident

Horodatage	Événement
07/03/2026 - 09h19	Premier scan de reconnaissance Nmap depuis 192.168.50.5 (Kali Linux)
07/03/2026 - 10h03	Dépôt et premier accès au webshell /var/www/html/shell.php
07/03/2026 - 11h06	Lancement brute-force SMB (67 tentatives en 42 minutes)
07/03/2026 - 11h49	Compromission du compte Administrateur (Event ID 4624 - mot de passe : Admin123)
07/03/2026 - 12h11	Session RDP établie sur WIN-HKVM4FR00PS depuis 192.168.50.5

07/03/2026 - post 12h11	Exfiltration du dump SQL Clinique Saint-Jean + déploiement ransomware
08/03/2026 - 09h51	Reverse shell bash vers 192.168.50.5:4444 - maintien d'accès
19/04/2026 - 14h20	Détection par le SIEM - ouverture INC-2026-001 - T0 de la réponse
19/04/2026 - post T0	Contention, éradication, récupération exécutées selon NIST SP 800-61

1.3 Cadre réglementaire applicable

Iron4Software se trouve dans une position réglementaire spécifique et doublement contrainte, qu'il convient de formaliser avant toute communication.

Position d'Iron4Software au sens du RGPD

Iron4Software est **sous-traitant** au sens de l'Article 4(8) du RGPD. En tant qu'éditeur du logiciel IronSuite, Iron4Software traite des données pour le compte de ses clients, qui sont eux les **responsables de traitement**.

La Clinique Saint-Jean est responsable de traitement de ses données patients. Iron4Software est son sous-traitant. Cette distinction génère une chaîne d'obligations distinctes pour chacune des deux entités.

Obligation	Iron4Software (sous-traitant)	Clinique Saint-Jean (resp. traitement)
Art. 33 - Notification CNIL	Informier immédiatement le responsable de traitement (la Clinique)	Notifier la CNIL sous 72h depuis la connaissance de la violation
Art. 34 - Notification personnes	Pas d'obligation directe envers les patients	Évaluer et notifier les patients si risque élevé pour leurs droits et libertés
Art. 28 - Contrat sous-traitance	Vérifier la conformité du DPA et ses clauses incident	Actionner les clauses contractuelles de notification et de responsabilité
Art. 9 - Données de santé	Appliquer le régime renforcé : évaluation de risque obligatoire	Mener une analyse d'impact (DPIA) et informer les personnes si nécessaire

Conséquence directe : la notification CNIL n'est pas de la responsabilité directe d'Iron4Software dans la chaîne formelle, mais Iron4Software a l'**obligation légale d'informer la Clinique Saint-Jean sans délai** afin que celle-ci puisse respecter son propre délai de 72h. La notification CNIL incluse dans ce document est rédigée à titre de support pour la Clinique Saint-Jean, et non en tant qu'acte autonome d'Iron4Software.

2. Communication interne - Direction et COMEX

Ce message est destiné à la direction générale d'Iron4Software. Il doit être transmis dans les heures suivant la détection de l'incident, avant toute communication externe. La direction doit valider les décisions de communication vers les clients et la CNIL, et assumer les conséquences business de l'incident.

2.1 Note de situation - Usage interne confidentiel

À : Direction Générale - Iron4Software

De : Responsable SOC / RSSI

Date : 19 avril 2026 - 16h00 CEST

Objet : **[CRITIQUE - CONFIDENTIEL] Incident de sécurité majeur - INC-2026-001 - Action requise**

Madame, Monsieur,

Je vous informe d'un incident de sécurité informatique de niveau critique ayant affecté notre infrastructure de production. L'incident a été détecté ce jour à 14h20 et est désormais contenu. Les actions techniques d'urgence ont été exécutées. Cette note a pour objet de vous informer de la situation, de ses conséquences et des décisions qui requièrent votre validation.

NATURE DE L'INCIDENT

Notre infrastructure a subi une intrusion informatique ayant abouti au déploiement d'un ransomware et à l'exfiltration de données sensibles. L'investigation technique a établi que l'attaque a débuté le 7 mars 2026 et n'a été détectée que le 19 avril 2026, soit 43 jours après l'entrée de l'attaquant dans notre système.

SYSTÈMES AFFECTÉS

Serveur web Apache (192.168.3.11) : compromis via une vulnérabilité d'upload de fichier.

Serveur Windows - contrôleur de domaine (WIN-HKVM4FR00PS, 192.168.3.10) : compromis via brute-force du compte Administrateur, puis accès graphique complet via RDP.

DONNÉES COMPROMISES - POINT CRITIQUE

L'attaquant a exfiltré le fichier Dump_SQL_IronSuite_Clinique_StJean_PROD.bak depuis notre serveur Windows. Ce fichier est une copie de la base de données de production de notre client, la Clinique Saint-Jean. Il contient des données de santé de patients.

Conséquence réglementaire directe : en tant que sous-traitant de la Clinique Saint-Jean au sens du RGPD, nous avons l'obligation légale d'informer notre client sans

délai. La Clinique dispose ensuite de 72 heures pour notifier la CNIL depuis le moment où elle est informée. Tout retard de notre part engage notre responsabilité contractuelle.

ACTIONS DÉJÀ EXÉCUTÉES

- L'adresse IP de l'attaquant a été bloquée au niveau du pare-feu.
- Le serveur Windows a été isolé du réseau.
- Le compte Administrateur compromis a été réinitialisé.
- Le webshell a été supprimé du serveur web.
- Les services ont été remis en production de manière contrôlée.

DÉCISIONS REQUISES DE LA DIRECTION

1. Valider l'envoi du message de notification à la Clinique Saint-Jean - délai critique.
2. Valider si Iron4Software souhaite déposer une plainte auprès des autorités judiciaires.
3. Évaluer l'opportunité d'une communication préventive vers les autres clients du secteur santé.
4. Mandater un prestataire externe pour un audit de sécurité post-incident.

Je reste disponible pour toute question et pour une réunion de crise à votre convenance dans les prochaines heures.

Le Responsable SOC - Iron4Software

3. Communication externe - Client Clinique Saint-Jean

Ce message constitue la notification obligatoire qu'Iron4Software doit adresser à son client en tant que sous-traitant RGPD. Il doit être transmis le plus rapidement possible après détection, car le délai de 72 heures imposé à la Clinique par l'Article 33 court à compter du moment où elle est informée. Ce message doit être envoyé après validation de la direction.

Attention - Enjeu contractuel et réglementaire

Iron4Software est lié à la Clinique Saint-Jean par un contrat de sous-traitance RGPD (Data Processing Agreement - DPA). Ce contrat inclut une clause de notification obligatoire en cas de violation de données. Le non-respect de ce délai expose Iron4Software à des pénalités contractuelles. La transparence totale est la seule posture légalement et commercialement défendable.

3.1 Notification de violation de données

À : Direction et Responsable de traitement - Clinique Saint-Jean

De : Responsable SOC / RSSI - Iron4Software

Date : 19 avril 2026 - 18h00 CEST

Objet : **[URGENT - CONFIDENTIEL] Notification de violation de données vous concernant - Action requise sous 72h**

Madame, Monsieur,

Nous vous contactons en urgence pour vous informer d'un incident de sécurité affectant des données dont vous êtes responsable de traitement. Conformément à nos obligations contractuelles (accord de sous-traitance RGPD) et à l'Article 28 du Règlement Général sur la Protection des Données, nous vous notifions sans délai la violation de données décrite ci-après.

NATURE DE LA VIOLATION

Notre infrastructure a fait l'objet d'une intrusion informatique. Un attaquant a obtenu un accès non autorisé à notre serveur interne et a exfiltré un fichier vous appartenant.

DONNÉES CONCERNÉES

Fichier exfiltré : Dump_SQL_IronSuite_Clinique_StJean_PROD.bak

Nature des données : Base de données de production IronSuite - données de santé de patients.

Catégorie RGPD : Données de catégorie particulière au sens de l'Article 9 du RGPD (données relatives à la santé).

Origine du fichier : Copie de la base de données stockée sur notre serveur interne dans le cadre de la maintenance applicative d'IronSuite.

CHRONOLOGIE DES FAITS

- 7 mars 2026 : début de l'intrusion non détectable à cette date.
- 7 mars 2026 après 12h11 : exfiltration du fichier identifiée par analyse forensique.
- 19 avril 2026 - 14h20 : détection de l'incident par notre SIEM.
- 19 avril 2026 - post 14h20 : actions de confinement et d'éradication exécutées.
- 19 avril 2026 - 18h00 : présent message de notification.

MESURES PRISES PAR IRON4SOFTWARE

- Blocage de l'adresse IP de l'attaquant au niveau du pare-feu périmètre.
- Isolation du serveur compromis.
- Réinitialisation et renforcement de l'ensemble des comptes privilégiés.
- Suppression du vecteur d'intrusion initial (webshell).
- Analyse forensique complète de l'incident conduite en interne.
- Revue et renforcement de la politique de contrôle d'accès aux données clients.

VOS OBLIGATIONS EN TANT QUE RESPONSABLE DE TRAITEMENT

En tant que responsable de traitement, vous êtes soumis aux obligations suivantes depuis le moment où vous prenez connaissance de cette notification :

Article 33 RGPD : vous disposez de 72 heures pour notifier cette violation à la CNIL. Le délai commence à courir à compter de la réception du présent message. Le formulaire NotifViol est disponible sur [notifications.cnil.fr](https://www.notifications.cnil.fr).

Article 34 RGPD : vous devez évaluer si la violation est susceptible d'engendrer un risque élevé pour les droits et libertés de vos patients. Compte tenu de la nature des données (données de santé - catégorie particulière Art. 9), nous estimons que le risque pour les personnes concernées doit être qualifié d'élevé, ce qui rend l'obligation de notification aux patients concernés très probablement applicable.

Nous mettons à votre disposition l'intégralité des résultats de notre analyse forensique, incluant la timeline précise de l'incident, les indicateurs de compromission identifiés, et les preuves techniques de l'exfiltration. Ces éléments sont nécessaires à la constitution de votre dossier de notification CNIL.

Nous vous prions d'accepter nos sincères excuses pour cet incident et vous assurons de notre entière coopération dans la gestion de cette situation.

Le Responsable SOC - Iron4Software

Contact direct : [coordonnées du RSSI]

Ce document constitue un support de notification formalisé selon les exigences de l'Article 33 du RGPD et du formulaire NotifViol de la CNIL. Il est rédigé par Iron4Software à l'intention de son client la Clinique Saint-Jean, responsable de traitement, qui a seul la qualité pour déposer formellement cette notification auprès de la CNIL. Les éléments techniques fournis sont issus de l'analyse forensique conduite sur l'incident INC-2026-001.

Contrainte temporelle - Article 33 RGPD

T0 de détection : 19/04/2026 à 14h20 CEST.

Échéance de notification CNIL : 22/04/2026 avant 14h20 CEST (72 heures).

Toute notification incomplète peut être acceptée sous réserve de complément ultérieur, mais le dépôt initial doit intervenir dans ce délai.

4.1 Éléments de notification (Art. 33 RGPD)

Identité du responsable de traitement et du sous-traitant

Champ	Valeur
Responsable de traitement	Clinique Saint-Jean - [adresse et coordonnées à compléter]
Sous-traitant notifiant	Iron4Software - éditeur du logiciel IronSuite
DPO ou référent RGPD	[À compléter par la Clinique Saint-Jean]
Contact technique	Responsable SOC Iron4Software - [coordonnées]

Nature de la violation (Art. 33.3.a)

La violation constitue une atteinte à la confidentialité et potentiellement à la disponibilité des données (ransomware). Elle relève de la catégorie des violations par accès non autorisé avec exfiltration. La compromission a été obtenue par l'exploitation d'une vulnérabilité applicative (upload de fichier PHP), suivie d'un brute-force d'identifiants Active Directory.

Catégories et nombre approximatif de personnes concernées (Art. 33.3.b)

Élément	Description
---------	-------------

Fichier concerné	Dump_SQL_IronSuite_Clinique_StJean_PRO D.bak
Type de données	Données de santé - catégorie particulière Art. 9 RGPD
Contenu probable	Données patients : identité, informations médicales, historique de soins
Nombre de personnes	À déterminer par la Clinique Saint-Jean après analyse du fichier
Période couverte	À déterminer par la Clinique - données de production à la date du 7 mars 2026

Note : Iron4Software ne dispose pas de la structure interne du schéma de base de données suffisante pour déterminer précisément le volume de personnes concernées. La Clinique Saint-Jean, en tant que responsable de traitement, est en mesure d'effectuer cette détermination.

Conséquences probables de la violation (Art. 33.3.c)

Compte tenu de la nature des données (données de santé - catégorie particulière), les conséquences probables pour les personnes concernées incluent :

- Risque d'utilisation frauduleuse des informations médicales (discrimination, chantage, usurpation d'identité médicale).
- Risque d'atteinte à la vie privée des patients dont les pathologies pourraient être divulguées.
- Risque de revente des données sur des marchés clandestins, compte tenu du profil double extorsion de l'attaquant.
- Risque psychologique et social pour les patients concernés en cas de divulgation publique.

Évaluation du risque au sens de l'Art. 34 : au vu de la catégorie des données (santé) et de la nature de la violation (exfiltration confirmée vers un tiers externe), le risque pour les droits et libertés des personnes concernées doit être qualifié d'**élevé**. L'obligation de notification aux personnes concernées (Art. 34 RGPD) est par conséquent fortement applicable.

Mesures prises ou envisagées pour remédier à la violation (Art. 33.3.d)

Mesure	Statut	Date
Blocage de l'IP attaquante au pare-feu	Exécutée	19/04/2026

Isolation du serveur compromis	Exécutée	19/04/2026
Réinitialisation des comptes privilégiés	Exécutée	19/04/2026
Suppression du vecteur d'intrusion (webshell)	Exécutée	19/04/2026
Analyse forensique complète	Exécutée	19-23/04/2026
Renforcement de la politique d'accès aux données clients	En cours	Q2 2026
Mise en place d'une politique de sauvegarde 3-2-1	Planifiée	Q2 2026
Audit de sécurité externe post-incident	Planifié	Q2-Q3 2026
Révision des contrats DPA avec l'ensemble des clients	Planifiée	Q2 2026
Formation des équipes à la gestion des données clients	Planifiée	Q3 2026

4.2 Évaluation du risque - Article 9 et Article 34 RGPD

Les données de santé constituent une catégorie particulière de données au sens de l'Article 9 du RGPD. Leur traitement est en principe interdit, sauf dans des cas spécifiques dont la prise en charge médicale. L'exfiltration de telles données par un tiers non autorisé constitue une violation d'une gravité maximale dans l'échelle de risque RGPD.

Critère d'évaluation	Niveau	Justification
Sensibilité des données	Maximal	Données de santé - catégorie Art. 9 RGPD
Volume probable	Significatif	Base de production intégrale - volume à déterminer
Nature de la violation	Critique	Exfiltration confirmée - données hors périmètre contrôlable

Intentions de l'attaquant	Risque élevé	Profil double extorsion - monétisation probable des données
Réversibilité	Non réversible	Les données exfiltrées ne peuvent pas être récupérées
Risque global pour les personnes	ÉLEVÉ	Notification Art. 34 recommandée à la Clinique Saint-Jean

5. Procédures de gestion de crise et gouvernance

5.1 Arbre de décision - Qui informe qui et quand

Étape	Acteur	Destinataire	Délai depuis T0	Base légale
1	SOC / RSSI Iron4Software	Direction Iron4Software	H+2	Obligation interne
2	Direction Iron4Software	Clinique Saint-Jean (resp. traitement)	H+4 maximum	Art. 28 RGPD + DPA
3	Clinique Saint-Jean	CNIL (NotifViol)	72h depuis notification Iron4Software	Art. 33 RGPD
4	Clinique Saint-Jean	Patients concernés	Sans délai si risque élevé confirmé	Art. 34 RGPD
5	Direction Iron4Software	Autres clients secteur santé (évaluation)	Décision dans les 48h	Gestion de risque

5.2 Consignes de communication en période de crise

Consignes strictes pendant la période de crise

Aucune communication publique (presse, réseaux sociaux, clients non concernés) ne doit être effectuée sans validation explicite de la direction.

Tout membre du personnel interrogé sur un incident de sécurité doit rediriger vers le RSSI ou la direction. Aucune information technique ne doit être divulguée.

Les communications relatives à cet incident sont classifiées CONFIDENTIEL jusqu'à levée de cette restriction par la direction.

En cas de contact par les médias, ne pas confirmer ni infirmer et rediriger vers la direction.

5.3 Suivi et clôture

Action de suivi	Responsable	Échéance
-----------------	-------------	----------

Confirmation de réception par la Clinique Saint-Jean	RSSI Iron4Software	J+1
Vérification du dépôt de notification CNIL par la Clinique	Direction Iron4Software	J+3
Point de situation interne - avancement mesures correctives	RSSI Iron4Software	J+7
Rapport de clôture de la crise de communication	RSSI Iron4Software	J+14
Revue post-incident (REX) avec la direction	RSSI + Direction	J+21
Audit externe de sécurité post-incident	Direction Iron4Software	J+30 à J+90